

OLIVER WYMAN
A MARSH BUSINESS

| HAWK

管理AFC代理

模型治理与验证如何演变以适应具有自主行动能力的AI在金融犯罪合规领域的应用

摘要

金融机构正开始在反金融犯罪（AFC）系统中部署具有自主性的AI，而监管环境仍在不断演变。现有的关于模型风险管理（MRM）的监管指南、如欧盟AI法案等新兴的横向AI治理框架以及行业在金融犯罪中应用AI的原则，都提供了重要的治理原则。然而，这些都没有为具有自主性的AFC系统提供一个完整的框架，后者的自主规划、工具使用、动态工作流程和授权决策带来了独特的治理问题。

本文提出了一种适用于机构当前应用的自主金融科技公司（AFC）系统的实用治理框架。该框架并非取代现有指导方针——包括跨机构模型风险管理指导、沃尔夫斯贝格人工智能原则以及金融行动特别工作组（FATF）关于人工智能的工作——而是确定了在现有监管指导方针中仍然适用的治理原则，并引入了管理在AFC环境中运行的自主系统所需的额外控制措施。

全文中，我们以美国货币监理署（OCC）跨机构模型风险管理指南为例，因其提供了一个为许多合规和模型风险团队所熟悉的治理生命周期，阐述了现有治理原则如何扩展应用于自主式自动柜员机（AFC）系统。由此产生的建议旨在本身作为一个治理框架，适用于自主式自动柜员机系统，并可适用于不同的监管和监管体系。

无论是内部开发还是向第三方采购，每个物料代理人都应连接到企业代理保证层，该层允许机构进行配置、测试、观察、挑战、约束和停止系统，并保留用于监管的证据。

核心论点是，有效的监督必须从管理独立模型转向管理更广泛的代理系统。该系统的固有物质性由业务用例决定，但其残余风险以及其所需的相应治理和控制可以通过围绕自主性、工具权限、工作流约束和运行时安全措施进行的工程选择来塑造。采用这种更广泛的治理视角的机构将能更好地部署安全、有效且符合不断变化的监管预期的代理式人工智能。

内容

摘要2

在专门的指导方针出台前，为AFC管理代理式人工智能 4

2. 定义代理式AFC系统 7

3. 将现有治理原则应用于能动型AFC 9

4. 代理风险与基于风险的实质性框架 11

5. 代理开发与系统使用 16

6. 代理验证与监控 19

7. 治理、控制与权限 26

8. 供应商和第三方代理解决方案：无责任转移的保障 28

9. 示例：一名反洗钱调查代理人员

10. 从框架到制度实践 35

11. 结论 36

在专门的指导方针出台前，为AFC管理代理式人工智能

反金融犯罪计划正进入一个注重实效的时代。美国的方向——反洗钱法案强调对政府“高度有用”的信息、转向结果导向的审查，以及监管姿态从重流程、对框框进行核查转向——正推动机构走向基于风险、以结果而非活动来衡量成效的计划。在此背景下，金融机构正采用自主型人工智能用于调查及其他合规活动中，以加强其反金融犯罪风险管理并提升其计划质量，且通常早于任何关于如何治理这些系统的正式指导。这样做要求机构将问责、验证、监督和控制等既定原则转化为适用于能够规划、使用工具和行使授权的系统所需的形态。

这创造了一个实际的治理挑战。机构必须运用并监督一种全新的技术，而所使用的监管框架是为上一代分析和人工智能系统开发的。在网络安全、数据治理、身份与访问管理、隐私和运营风险等领域现有的框架解决了这一挑战的重要部分；然而，它们通常不提供针对端到端智能体系统的集成治理模型，包括其自主规划、工具使用、动态工作流程、授权委托以及与人类决策者的交互。在专门的治理框架出现之前，机构需要一种实用的方法，将当今的监管原则应用于智能体人工智能，并加以扩展。

现有的模型风险指引为持续有效的治理原则和当前框架的界限提供了有用的说明。2026年4月更新的美国跨机构模型风险管理监管指南，废止并取代了长期有效的2011年指引（SR 11-7/OCC 2011-12）以及2021年关于BSA/AML系统的跨机构声明。

2020年反洗钱法（AMLA），该法案要求银行特定反洗钱报告“极具价值”，并确立了国家反洗钱/反恐怖融资优先事项；后续的FinCEN及跨机构材料进一步强化了以结果和有效性为导向的方法。

与此同时，它明确界定了自身的边界。它将“模型”定义为一种复杂的定量方法，该方法应用统计、经济或金融理论来产生定量估计，并随后明确指出生成式和具身式人工智能不在其范围内——同时明确说明，这并非豁免控制：

生成式人工智能和代理式人工智能模型是新颖且快速发展的。因此，它们不属于本指南的适用范围。尽管如此，银行机构的风险管理和治理实践应指导确定本文件未涵盖的任何工具、流程或系统的适当治理和控制措施。

本文以此为基础展开。它并非取代现有的监管指南，而是识别出在当今框架下仍然适用的治理原则，并引入了管理实际运行中的代理式自动交易系统所需的额外控制措施。

代理机构（AFC）引入的基本治理挑战在于，对其核心中基础模型的训练过程缺乏影响力，也缺乏透明度。因此，治理必须围绕一个不透明的核心构建，利用机构能够直接管理的要素：代理机构的授权和操作指令、其数据及工具的访问权限、其被允许采取的行动、需要人类批准的环节，以及用于审查和重建其活动的记录。

机构可以借鉴既有的监管、风险管理及行业原则，但必须将这些原则转化为适用于更广泛能动性系统的治理方法。由于美国合规和模型风险团队最熟悉的是OCC跨机构模型风险指导提供的治理框架，我们将其作为实用的组织参考，而非作为自身的治理框架。我们还借鉴了更广泛的行业指导，包括沃尔夫斯贝格集团在金融犯罪合规中使用人工智能和机器学习的原则²，以及金融行动特别工作组（FATF）关于人工智能和深度伪造的2025年12月展望扫描³，后者因通过反洗钱/反恐怖融资（AML/CFT）视角明确将能动性人工智能列为新兴关注点而引人注目。

2 沃尔夫斯贝格集团，《在反洗钱合规中使用人工智能和机器学习的原则》（2022年12月）。其五项要素为：合法目的；合理使用；设计和专业技术；问责与监督；以及公开与透明。3 金融行动特别工作组，《前瞻性扫描：人工智能与深度伪造》（2025年12月22日）——通过反洗钱/反恐怖融资/反制洗钱与恐怖融资的视角，对与人工智能相关的风险和趋势进行的前瞻性评估，包括生成式人工智能和代理式人工智能。

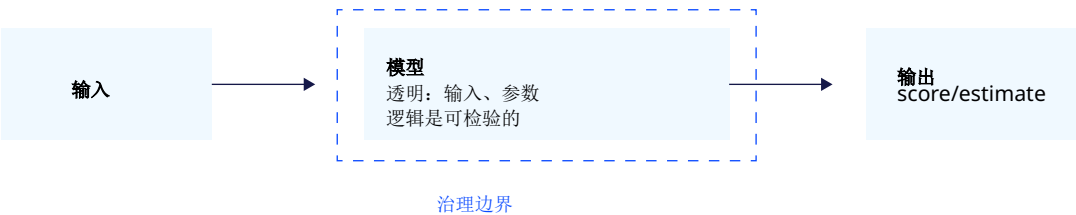
全文中，我们采用一致的三棱镜方法来审视现有的治理框架：（1）哪些原则仍然直接适用；（2）代理系统中出现哪些重要空白；（3）解决这些空白所需的额外控制措施。

贯穿全文的核心转变在于治理单元从模型转向代理系统——也就是说，该模型与其驾驭系统（即协调和调用工具的框架）、其可访问的数据、其可采取或推荐的行动、其升级求助的人类，以及其留下的审计追踪。

图1：从模型到 workflow：治理单元的扩展

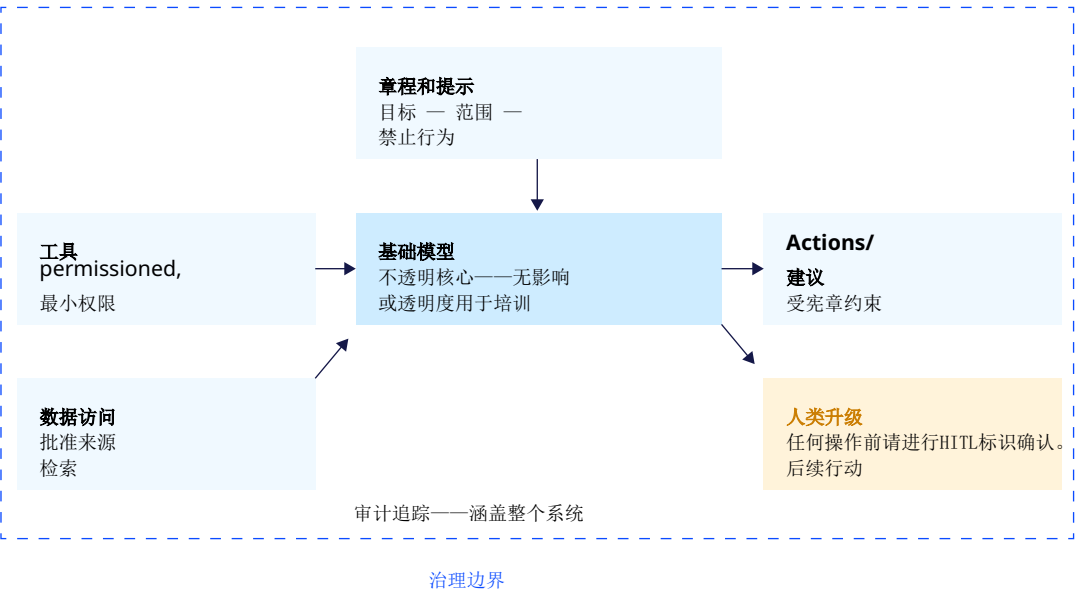
经典型号

该模型是治理的基本单位



代理系统

整个系统是治理的单位



欧文咨询和霍肯分析。

管理该扩展单元依赖于一个企业代理保证层，该层允许代理——无论是内部开发还是第三方提供——进行注册、测试、观察、控制和证明。

2. 定义代理式AFC系统

治理范围取决于被治理对象的定义。在本论文中，AFC代理被定义为一种有边界、具备人工智能的系统，该系统在批准的数据源和工具中追求调查或控制目标。AFC代理执行的活动可以包括，例如，收集和交叉引用证据、总结警报、排序调查步骤、识别类型、建议升级、起草可疑活动描述，或质疑案例的逻辑。我们互换使用“AFC代理”和“自主系统”这两个术语。两者均指这个复合系统——一个模型及其工具、数据访问、编排和控制——而不是指单个模型。

AFC代理并非单一的大型语言模型，也非聊天机器人。它更应被理解为一个组件系统，该系统组装起来以模拟调查员的业务流程，并包含推理模型、用于调用外部系统和数据的一组工具、记忆层或检索层，以及编排逻辑（该逻辑负责编排步骤）。这种构成方式正是为何代理不能作为单一模型进行管理的原因：其行为源于各部分以自身节奏变化的交互。

值得将智能体与传统人工智能以及无决策自主权的生成式人工智能区分开来，因为这种差异决定了治理方式：

表1：传统人工智能、无自主能力的生成式人工智能与能动式人工智能的比较

维度	传统人工智能	生成式人工智能 无自主权	代理型人工智能
核心功能	预测，分类，和 结构化数据	创建内容 对提示的回应	制定并执行计划 执行步骤的顺序 达到目标
自主性与行动	低 — 遵循明确指示 逻辑，从不主动发起	低 — 对...有反应 提示，不采取 独立行动	高一分解 目标，选择工具，和 行为或推荐
决策速度	毫秒 —— 为此而生 实时评分	秒到分	几分钟到几小时 — 精心策划了一场多 步骤工作流
决定论	高 — 相同输入 产生相同的输出	随机输出 可以不同	随机与路径 依赖行为 可能因运行而异
治理对象	模型（输入， 参数，输出）	模型加 提示	整个工作流程： 模型 + 工具 + 数据 访问 + 行动 + 人类升级+ 审计追踪

AFC代理涵盖广泛的应用场景和自主性——从调查副驾驶和欺诈分析师支持，到筛选处置、可疑活动报告（SAR）撰写、类型分析、风险暴露映射和系统优化。在设计驱动的自主性与对重大结果的内生邻近性方面，这种范围内的重要性差异巨大。

随着时间的推移，这一谱系中的重复设计可能会逐渐稳定为少数几个原型（例如筛选-处置代理或SAR起草者），每个原型都带有其特有的风险概况，并由此衍生出其特有的控制集。该学科仍在兴起，我们预期当今的机构会对代理逐一进行评估和批准；然而，随着投资组合的扩大，识别这些原型能够让常见且易于理解的设计基于共同基准进行验证并获得更快批准，同时稀缺的验证工作则集中于某个特定代理中真正新颖或高风险的部分。

图2：调查全生命周期中AFC代理的使用场景范围



AFC代理在警报和调查生命周期的使用案例——分析师审查之前、期间和之后

3. 将现有治理原则应用于代理型自动售货机

现有的关于模型风险管理、横向人工智能治理框架以及行业原则的监管指南，都为人工智能系统提供了宝贵的治理原则。尽管它们在范围和目的上有所不同，但它们都包含共同的主题：基于风险的治理、明确的责任、验证、持续监控、文档记录和独立监督。

自主式AFC系统并未使这些原则失效，反而揭示了现有框架的不足之处。自主规划、工具使用、动态工作流程和授权决策带来了治理问题，这些问题在传统模型治理中基本缺失，在更广泛的AI治理框架中也仅得到部分解决。因此，挑战并非要取代今天的治理框架，而是要扩展或增强它们，以涵盖更广泛的自主式系统。

表2以OCC跨机构模型风险管理指南为例，说明了该方法。OCC框架为许多金融机构提供了一个熟悉的治理生命周期，使其成为展示现有原则如何应用于治理代理式AFC系统（以及必须在哪里加以改进）的有用参考点。对于每个治理组件，该表格确定了：（1）仍然直接适用的原则，（2）代理系统引入的治理空白，以及（3）解决这些空白所需的附加控制措施。

自主式 AFC 在现有治理原则的基础上构建，但需要超越模型本身的控制机制。这些机制应涵盖代理自主性、工具使用、动态工作流、运行时监控以及对结果明确的责任追究等方面。

表2：应用和扩展OCC模型风险指引的代理AFC示例

OCC模型 风险组成部分	Similarity/applicability 为主动	指导中的空白 为主动	如何弥补差距
模型开发 implementation, 并且使用	定义预期 使用, 假设 目标, 测试 以及使用限制 直接适用 代理人	没有概念 授权 自主程度, 或 系统可以采取的行动 取或推荐。	定义代理权状: 有界目标 自主性/实质性层级, 授权 权威, 升级逻辑, 禁止行为
概念上的合理性	仍然有必要 为了评估是否 潜在模型(式) 设计精良且合身 为特定目的而设计; 适用舞台评论。	假定单一 统计模型具有 稳定输入/输出 关键挑战在于 绕过 不透明的基础 模型——沉默不语 提示, 工具选择 编排, 数据 访问范围	将合规性审查扩展到章程。 指令/提示, 工具权限 检索设计, 以及编排逻辑。
持续监测	持续表现 监控和 流程验证 保持关键; 漂移 检测适用。	静态输入/输出 监控疏漏 行为漂移 non-determinism , 并且提示/工具/ 模型更新 在评论之间	运行时行为监控(路径和) 决策日志记录、将LLM作为裁判、护栏/ 异常警报, 由重新验证触发 材料配置或型号变更——不仅仅是 数据漂移
结果分析 可解释性	将输出与... 进行比较 预期成果与 解释决定 核心; 特性 可解释性水平 作为 SHAP — SHapley 值 附加说明) 仍然适用 任何贡献 统计模型。	Single-decision 分析不涵盖 多步推理 锁链, 证据 传承、引文或 一个组合的人 AI审计追踪。内部 工作原理可解释性 例如 SHAP 不适用于 不透明的基础 模型本身。	思维链级别的可解释性; 引文 时间戳记录的、防篡改的 源头的即时快照 已访问; 工作流路径的可审计性 已采取, 包括每一步的结果; 与AFC效能挂钩的结果指标 (例如提高搜救质量、降低误报率)
治理, 政策 以及控制 (角色/) authority)	董事会和高级管理层 管理 accountability , 独立挑战 清晰的角色分工 完全适用。	不映射决策 人与人之间的权利 代理人, 或定义 谁拥有代理人 跨AFC的行为 MRM 技术/供应商	定义人类决策权以及人- 闭环控制 (HITL) 控制; 分配代理 所有权; 使代理与人类意图保持一致; 向能动性发起独立挑战 工作流; 偏差/公平性测试; 常规 对数据鲁棒性测试 中毒攻击
模型库存 以及文件	保持 库存和 文档 适用。	库存设计 对于离散模型; 代理人结合 模型, 工具, 提示 以及数据连接 随着时间的推移而变化。	代理/工作流清单捕捉 组件、版本、权限和 修改历史; 将配置/提示视为 版本化的、有文档记录的工作件。
Vendor/ 外部模型	供应商模式- 风险原则 验证, 持续进行中 监控适用。	有限的指导 验证供应商 代理机构, 其 编排 部分不透明。	供应商代理验证与定制 控件; 工具/合同的透明度 数据; 持续联合监测; 客户 保留激活和决策权。

4. 代理风险与基于风险的实质性框架

在AFC领域，将统一治理模式应用于人工智能在操作上效率低下，甚至可能存在风险。将低风险内部负面媒体汇总工具与交易阻断代理置于相同的验证周期会导致资源瓶颈并延缓实施。相反，对交易性、高影响代理实施宽松控制则会引入显著的合规和运营风险。

为了安全且大规模地部署代理系统，机构需要建立一个基于风险的实质性框架，该框架能够根据代理活动的重要性来校准验证和监督。这种方法要求区分两个核心概念：

- **风险是对不确定性的前瞻性衡量。**它是发生概率（系统故障、幻觉或执行错误的概率）和影响（该故障带来的下游运营、财务或监管后果）的函数。
- **材料性是指客观存在的外部重要性门槛。**某一事件、决策或产出具有材料性，如果其发生、未发生或错报会影响到人类官员、审计师或监管者的决策。

在一个授权环境中，重要性是主要的筛选标准。通过首先评估业务流程的固有重要性，治理团队确立了监管基准。该框架并非试图从随机模型中消除所有风险，而是使用重要性来确定技术 harness 所需的稳健性。高重要性用例要求采用多层设计控制来降低残余风险，而低重要性用例则遵循简化的验证路径。

基于风险的实质性应反映用例的固有风险敞口及其技术控制的有效性。这使机构能够进行与其相称的治理，而无需将所有代理系统一视同仁。

4.1 代理系统的三分法风险分类

与传统的量化模型（静态且确定性）或独立的生成式人工智能工具（随机但交易性）不同，智能体式人工智能系统引入了复合风险敞口。尽管这三种人工智能类型之间的界限是流动的，但概念上可以将它们分为三元风险分类法：

经典模型风险（基础）

- 样本和数据偏差 • 过拟合与校准误差
- 概念和数据漂移

核心生成式AI风险（认知核心）

- 随机性及幻觉 • 提示词漏洞（注入攻击和越狱）
- 上下文窗口退化

独立代理风险（行动层）

- 规划失败与目标漂移
- 工具使用与API执行错误
- 级联传播（多智能体向量）
- 无界爆炸半径与不可逆性

4.2 双镜头物质性模型：固有属性与设计控制

新兴人工智能治理中一个常见的失败点在于将固有的物质性（或内在属性）与设计选择相混淆，也就是说，问题与解决方案的混淆。诸如“自主程度”或“工具访问权限”等因素并非用例的固有特征，而是工程师配置的技术控制手段，用以管理风险。

为建立一套有说服力的框架，机构必须通过双重视角模型来评估代理系统：

镜头1：纯粹的固有物质性（问题领域）

首个视角在考虑技术或治理控制的有效性之前，确立了用例的固有物质性。相关因素完全是外部的，在代理被设计之前完全由业务用例和运营环境决定。它们无法通过编写代码、调整提示或添加护栏来改变：

- **风险价值（金融风险敞口）**。指流程直接涉及的本金或交易量（例如，审核一笔100美元的零售交易，与管理一笔5000万美元的机构财库流动）。
- **流程关键性（运营风险）**。流程对机构持续生存的重要性。核心支付路由的失败会立即停止银行业务；而行政报告的失败 merely 仅会延迟一个内部周期。
- **监管和法律密集度（合规风险）**。管理该领域的法规框架（例如BSA/AML申报义务、OFAC制裁合规、GDPR或欧盟AI法案）。违规行为将面临固定的法律处罚和监管批评。
- **环境波动与摩擦（可逆性领域）**。目标系统的物理特性。修改内部数据库是低摩擦且完全可逆的；而写入公共账本或将文件提交给联邦金融情报单位则是高摩擦且实际上不可逆的。

镜头2：设计控制因素（技术整合）

第二个透镜评估技术 harness 如何限制风险敞口并降低残余风险。严格的设计控制或许能支持在更严格的参数下部署，但它们本身并不能改变问题领域的基本性质。这些是由开发团队（依据治理要求）强加的架构边界，用以限制代理的影响。

- **自主程度**。人机回路的设计配置，从辅助（“人在回路中”）转变为推荐（“人在回路外”）或自主（“人机分离”）。

这种双镜分类法的关键启示在于，设计选择充当了一个操作杠杆，用以主动确定代理部署所需的验证、监管、监控和控制水平，这也可以被描述为分配给代理的治理层。虽然机构无法改变业务领域的固有实质性，但可以通过有意的工程约束直接操纵剩余的治理层。

通过内在物质性和设计控制因素这两个双重视角来评估代理性用例，使机构能够将系统映射到四个不同的治理层级之一。这种分类决定了后续章节中规定的具体控制集。

表3: AFC代理机构的治理层级示例

治理 tier	代表 AFC示例	固有轮廓 (问题空间)	设计边界 (解空间)	核心治理与 验证措施
一级 低 (辅助)	负面媒体 摘要 (一个代理被用) 汇编和 总结 新闻文章用于 分析师评审)	- 低财务价值处于危险中 - 非关键流程。 - 最小化监管报告密度 - 低环境friction.	自主性: 辅助 (human-in-the-loop). 动作空间: 读 仅; 无系统写入 access. 断路器: 基础 会话时长和 令牌大写	- 第五章 (神): 已批准提示模板; 模型版本锁定 - 第六章 (估值): 中央库存注册; 用例对齐检查 - 第7章 (政府): 标准问答输出采样 - 第8章 (供应商): 标准第三方派对安保评估
二级 中等 (Analytical)	反洗钱调查 SAR草稿 代理 (An agent) 聚合 了解你的 Customer, 构建时间线 以及草稿 搜寻叙事 (用于签字确认)	- 轻度经济/运营影响 - 间接支持监管流程 - 可完全逆转环境 (人类) 审阅草稿。	Autonomy: 推荐 (human-on-the-loop). 操作空间: 只读 或高度受限 内部 写入权限 断路器: 输入/输出提示 注射过滤器	- 第五章 (开发): 强制性书面代理章程; 严格RAG基础定位 - 第六章 (价值): 黄金数据集测试; 覆盖率监控 - 第7章 (政府): 四人联签关于推荐; 分配老板 - 第8章 (供应商): 验证租户隔离数据处理
三级: 高 (Supervised)	PEP筛查 处置 自动驾驶 (一种) 代理 自主地 清除低风险 误报 并升级 matches).	- 交易量高风险敞口 - 核心监管合规流程 (例如, PEP/制裁筛查) - 适中的环境的friction.	自主性: 受监督 行动 (人-) 审批循环) 动作空间: 中等 写入权限 自动化API调用 断路器: 真实 时间交易率 以及容量限制。	- 第五章 (草稿): 已编撰的政策转换为顺序工作流; 严格保密管理 - 第六章 (估值): 运行时执行追踪; 子群体偏差/公平测试; 红队演练 - 第7章 (政府): 密码学委托工作负荷标识实时性能telemetry. - 第八章 (供应商) 沙盒验证 独立代码审计 供应商逻辑
四级: 关键 (Autonomous)	自动化 逃避制裁 阻断者 (一种代理) 阻挡线 转移和 冻结资产 在交易中 发动机级别)	- 高经济价值处于危险中 - 存在主义关键流程 - 密集监管/法律监督 - 不可逆转环境 (立即冻结)	Autonomy: 自主 (human-out-of-the- loop). 循环: 异常 仅升级) 动作空间: 交易写入 阻止权限 断路器: 自动化的, 硬件的 隔离式杀开关	- 第五章 (开发): 隔离执行沙盒; 独立评论家代理验证 - 第 6 章 (估值): 持续的 “大语言模型即服务” “审判” 审计; 数据中毒韧性测试 - 第 7 章 (治理): 董事会批准; 正式事件管控与回滚剧本 - 第8章 (供应商): 实时联合监控; 合同约定责任担保

例如，反洗钱调查代理人在一个合规要求极高的环境中运作。然而，通过严格设计系统采用推荐自主模型（二级），并拒绝其直接的交易写入访问权限（限制其行为范围），工程师们可以降低残余风险，并支持一种更受约束的部署态势。该系统遵循二级指南进行管理，避免了为四级系统保留的密集的、董事会级别的隔离开销。

相反，如果一个最初风险等级较低的Tier 1负面媒体摘要器被授予写入权限，能够自主向外部客户关联方发送电子邮件或更改客户关系管理（CRM）记录，那么其设计边界就发生了变化。这种设计扩展会立即将该代理推向Tier 3，从而触发强制性的严格验证要求（例如执行追踪、偏见测试和加密委托身份）。

因此，模型风险管理及合规团队必须将代理设计不仅视为一项工程任务，更应将其看作一个动态的治理旋钮。通过调整自主性、限制API工具集以及嵌入硬编码的断路器，机构可以有意减轻高度复杂用例的验证负担，实现速度与安全的平衡。

治理强度应随着代理人的剩余风险增加，而不仅仅取决于其用例。更强的设计边界可以支持低风险部署，而扩展的自主权、外部访问或不可逆操作则需要更严格的监管。

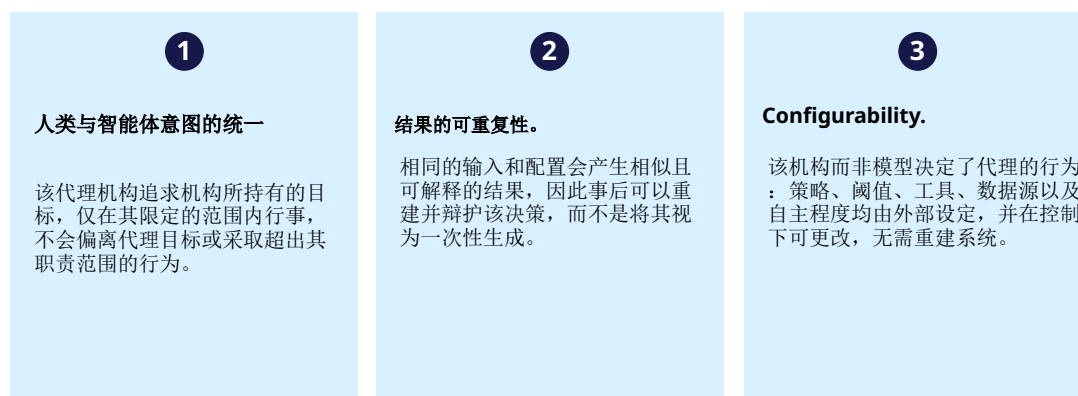
5. 代理开发与系统使用

现有的监管指南始终强调，人工智能系统在部署前应明确其目的、预期用途、已记录的限制，并经过适当测试。美国货币监理署的指南通过其期望来体现这些原则，即模型开发需与目的和用途保持一致，预期用途和限制需得到说明，且模型在首次使用前需经过测试。这些原则同样适用于代理式自动柜员机系统。

然而，治理应要求发展达成既定目标集，而非强制指定特定的系统构建方式。机构必须能够证明其代理满足这些目标；其实现方式是一种工程选择，这种选择会因具体应用场景、供应商以及机构的风险偏好而有所不同。由于低代码平台越来越多地允许几乎任何人构建接触敏感数据并执行操作的代理，因此构建过程本身需要与代理的重要性层级相匹配的监管措施。构建者从批准列表中选择模型、工具和数据；常见设计以模板形式提供；只有特定角色才能构建特定类型的代理；并且代理的权限属于代理本身，而非其构建者——因此，即使其创建者拥有写入权限，该代理也可以是只读的。

在实际操作中，许多此类控制需要通过机构更广泛的AI工厂内的企业代理保证层来提供。该层包含用于在机构范围内注册、测试、部署、监控、变更、暂停和证明代理所使用的共享技术和治理能力。其实施将取决于机构的云环境、代理 harness、评估工具、可观察性平台和现有的控制架构。这些选择可能会有所不同，但所需的结果不应如此：每个重要的代理都应该是可测试的、可观察的、版本受控的、可中断的，并且能够为独立审查提供证据。AFC应配置特定领域的策略、测试、阈值和决策权，同时依赖保证层来提供通用能力。

三个目标处于代理发展的核心。



基础文件是一份代理权章程：一份说明代理目标、其权责范围、被授予的授权以及被明确禁止采取的行动的书面声明。章程使得“预期用途和限制”对可行动的系统具有意义，并且它是所有后续控制（验证范围、决策权、监控）的参照依据。

章程是必要的，但不是充分的。实现目标取决于在共同决定代理人行为的各个要素中做出审慎的、有记录的选择：

1 系统提示和指令。 代理人的角色、运行人格、行为约束以及它在每一步都必须遵守的既定规则。

模型选择与版本锁定。 指使用哪个基础模型，以及固定其版本和解码参数的规范，以便能够一致地测试行为，并将结果的变化归因于已知的配置变更。

3 工具与权限。 代理可调用的具体工具，其读写范围设置为最小权限，以便一个被攻破或操作失误的代理所能造成的损害有限。

第四，数据访问与检索。 智能体可能使用的数据来源，以及使其基于已验证的当前信息进行检索的设计方案。

5 记忆与状态。 智能体在调查过程中保留的内部和跨调查信息，以及施加于该记忆的控制。

6 配置与控制流。 步骤如何排序，以及智能体被允许为自己规划多少，与遵循固定路径多少。

七道安全屏障：输入和输出验证、提示注入防御措施，以及内容和个人身份信息（PII）过滤器，这些措施均应始终有效，无论模型生成何种内容。

8 人机交互检查点和决策权。在代理采取行动之前，必须有人进行审查或批准。

9 评估和质量保证。测试框架和评估数据集，以及在必要时，用于在人类查看之前检查主要代理工作的质量保证代理或“评论家”代理。

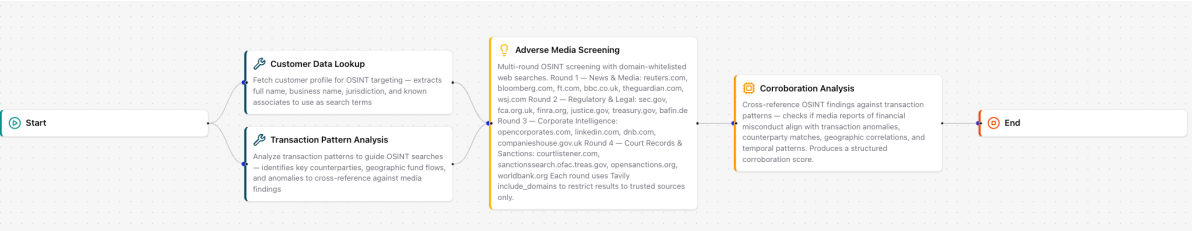
10 日志记录与可观察性。在构建时捕获的仪器配置，它使后续的监控和审计成为可能（第6章）。

采用工作流方法是把这些要素整合起来的有效方式。在这种方法中，机构的标准操作规程和政策被整合到代理人的工作流中。这是一个规定了代理人在每个步骤中必须或可以选择使用的工具、命名所需和可选的数据源、设置读写能力以及选择自主程度的一系列流程。

将代理约束为显式、基于策略的序列，可同时实现三个目标：意图直接编码在步骤中（对齐），允许的
执行路径受到限制，且运行间的差异可追溯（可重复性和可审计性），以及每个步骤的工具、数据和自主性均可单独调优（可配置性）。代理严格在那些边界内运行，且在需要最终审核或判断的地方精确插入人工介入检查点。基于规划、更自主的设计也是可能的，并且可能适合低重要性场景，在这些场景中，目标保持不变，但保证负担更多地从设计时约束转移到运行时监控。

部署前的测试则评估各个独立组件（底层模型、检索质量、每个工具）以及集成工作流的端到端行为，评估方式是使用具有代表性的案例——包括边缘案例、模糊输入，以及旨在让代理偏离其职责范围的输入。

附件3：不良媒体和开源情报筛选工作流定义示例



Source: Hawk.

6. 代理验证与监控

6.1 验证范围

验证从未局限于模型本身。它还包括影响系统运行方式的数据、处理步骤、接口和控制。对于自主系统而言，该范围更广，因为代理可能依赖多个数据源、调用工具或服务并启动操作。因此，验证应涵盖用例和章程；数据和工具访问；指令和检索设计；输出质量与证据溯源；升级和人工审批点；以及变更管理、监控和结果。任何可能实质性影响代理行为或结果的组件都应纳入验证范围。

6.2 将既有的验证原则扩展应用于代理式自动售票系统

既定的验证原则仍然为自主式AFC系统提供了有用的基础，但需要将其应用于更广泛、更动态的对象。重点不再仅仅在于一个离散模型的性能；它还必须考虑智能体的设计方式、其使用工具和数据的方式、其在多步骤工作流程中的行为方式，以及这些行为随时间的变化。

以OCC框架为说明参考，三个熟悉的有效性原则尤其具有相关性：概念上的合理性、结果分析与可解释性，以及持续监控。每一项都必须扩展，以反映代理系统所特有的不透明性、非确定性、编排和授权。

1. 概念上的合理性。现有的监管指南强调从模型设计、关键选择、假设和开发证据等方面评估量化组件。对于自主系统，评估范围扩展到设计和编排的合理性，包括其章程、指令和提示、工具权限、检索设计以及编排逻辑。由于基础模型不透明，评估应侧重于可测试和控制的内容，包括输出质量、基于可靠来源的支撑、基准性能以及周边控制的有效性。

4 OCC 2026-13a，第五部分。模型验证的组成部分包括：概念合理性评估、结果分析以及持续监测。

2. 结果分析与可解释性。将输出与预期结果进行比较仍然是核心。单一决策分析无法捕捉的是代理人的多步决策和执行路径。对于代理而言，可解释性需要对其采取的步骤、调用的工具、参考的来源、应用的决策标准、产生的输出、置信度指标以及人类干预进行操作追踪。这些共同构成了“人类+AI”的联合审计追踪记录。结果指标应与AFC（自动化决策支持系统）的有效性挂钩，例如SAR（社会风险分析）质量提升和误报率降低，而不仅仅是任务完成。代理人相关的具体指标及其与单一模型指标的差异，在 § 6.6 中详述。

3. 持续监控。性能监控和漂移检测仍然至关重要，但静态的输入/输出监控会遗漏行为漂移、非确定性以及正式评审之间发生的提示、工具或模型更新。因此，监控变得需要关注运行时和行为——记录路径和决策，对护栏违规和异常发出警报，并使用校准的自动化评估，辅以人工抽样，以识别不受支持的声明和错误的引用支持。任何实质性配置或模型变更都会触发重新验证。

6.3 偏见与公平

代理系统能够通过基础模型的固有偏差、它们的提示、它们检索的数据或它们进行调查研究的方式编码或放大偏见。因此，公平性测试应该是明确且可衡量的。有用的指标包括针对受保护属性和代理属性（例如性别、年龄、种族或民族、国籍）以及代理（例如地理或基于姓名的民族推断）的子群体假阳性率和假阴性率——此外还有差异化影响率、人口统计均等性差异、平等机会/平等化几率差距、预测均等性（跨群体的平衡精确度）、组内校准以及平均几率差异。使用受保护属性或代理进行公平性测试应获得法律、隐私和方法论的批准，仅限于评估目的，并由足够可靠的数据支持。

没有单一指标是绝对准确的，而且多个指标无法同时满足。针对某一公平性定义（例如，人口统计学均等）进行优化可能会损害另一个（例如，均衡机会），因此机构应选择并记录适用于特定应用场景的公平性定义。这些指标在部署前使用经过筛选的“黄金”数据集进行评估，并在部署后进行持续监控，数据质量下降被视为重新验证的触发条件和升级事件。

6.4 对抗鲁棒性与安全测试

代理系统可能处理不可信信息并调用外部工具或服务，从而产生需要特定控制的 security risks。Prompt 注入发生在内容包含旨在改变代理行为的指令时。控制措施应包括将检索到的内容与系统指令分离、验证输入和输出、限制对批准来源的访问、集中管理操作指令、对数据和工具应用最小权限访问，并筛选传入内容和建议的操作。数据中毒发生在源数据或参考数据被故意操纵时。缓解措施包括使用批准和经过验证的来源、维护数据溯源和完整性控制、监控源数据的变化，以及防止代理范围的无控制适应或扩展。

这些控制措施应在部署前进行测试，并在部署后定期进行。机构应评估系统的攻击面，并开展旨在诱导超出范围行为、未经授权访问、数据窃取或工具误用的对抗性测试和渗透测试。发现的问题应进行严重性评级、修复并跟踪至关闭。事件响应程序应涵盖检测、遏制、暂停或回滚、根本原因分析、恢复以及任何必要的通知或披露。

6.5 可观察性与追踪

所有以上内容都取决于能够看清代理实际做了什么。可观测性是指系统地捕获每个运行中代理的完整执行轨迹的能力，包括每个提示和模型响应、中间推理步骤、每个工具调用及其结果、检索的来源以及延迟、token成本和错误等操作信号。在此上下文中，轨迹是针对每个决策的粒度记录，而指标则是从许多轨迹中得出的聚合值。

在实践中，这由一个专门的可观测性层提供——即新兴的LLM追踪平台——该平台将追踪信息写入一个结构化、可查询且防篡改的存储库，并依据该机构的记录保存义务进行保留。这一层将一个不透明、非确定性的系统转变为可监督的系统。它支撑着思维链审计追踪和运行时监控、漂移与质量指标，以及事后事件根本原因分析。没有它，代理的行为无法事后重建；有了它，每个决策都可以一步步回放。

为避免在每个用例中重新创建可观察性，机构应在企业代理保障层中定义一个适用于云、代理平台和供应商解决方案的通用追踪和证据标准。AFC特定的指标应输入该层用于追踪捕获、访问控制、保留、监控和事件调查的通用功能。

6.6 持续测量与漂移

一套实用的AFC代理监控方案结合了模型质量、数据及业务信号：精确率和召回率（通过已裁决样本、已知结果或验证性回顾测试进行估算；或通过分析师覆盖与代理正面及负面评估的对比进行评估）；误报率、任务成功率、引用准确率、偏差与公平性指标，以及人工覆盖率；数据漂移和概念漂移（“可疑”定义的变动）；以及调查解决时间等业务信号。每个指标都有阈值和警报，持续违规将触发审查、重新校准或回滚。对于代理而言，覆盖率特别有用：上升的覆盖率是早期信号，提示或节点表现不佳需要关注。反之，异常低或下降的覆盖率可能表明人工审查不足。

6.7 推广：领先者/挑战者与分阶段部署

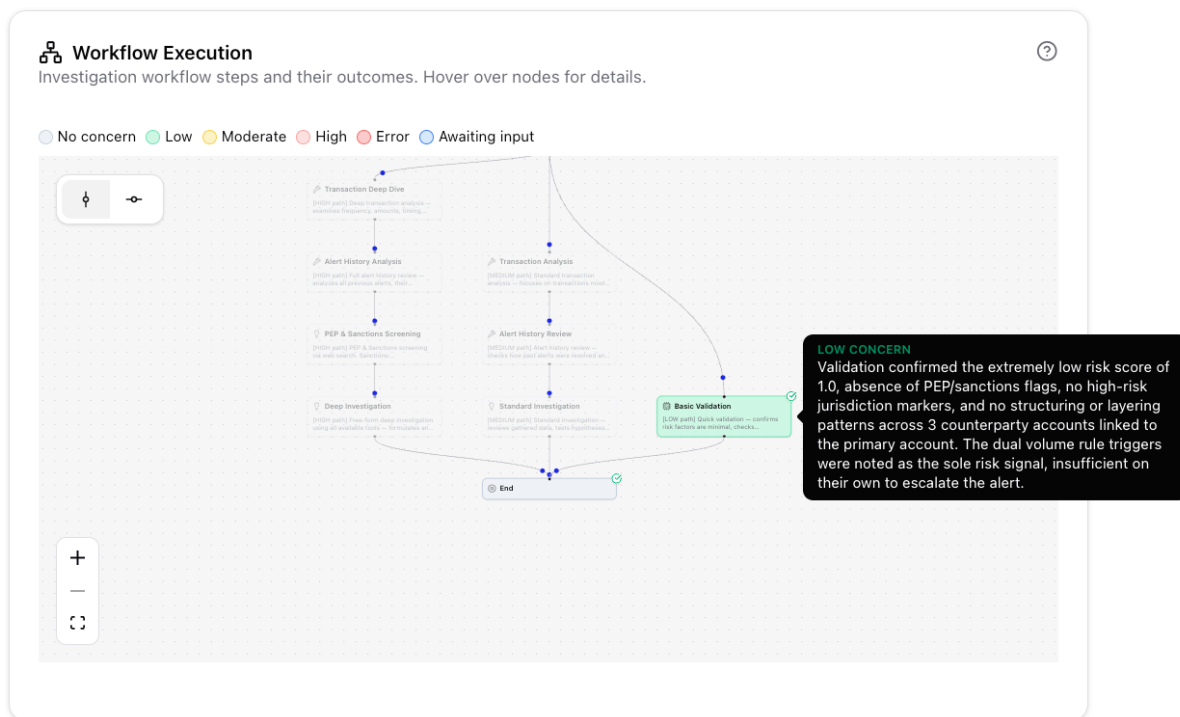
新 workflow、提示和模型版本不应全局启用。采用“领先者/挑战者”方法，在相同案例上，将所提议的变更（挑战者）与现有方案（领先者）进行对比，并在推广前比较结果。这通过影子运行或并行运行、试点到生产路径以及在黄金数据集上进行回测来加强，每个阶段都有明确的审批关卡。其结果是可控、可逆的发布，其中变更可以根据证据进行推广或回滚，而不会造成中断。

6.8 持续确保证书，而非一次性批准

综合来看，这些实践将验证从一次性的批准事件转变为持续的保证。相对于经典的模型验证，有两个元素是真正新颖的——对抗性/红队测试和运行时行为监控——它们都直接源于智能体会行动、读取不可信输入并以非确定性方式行事这一事实。经典的检测人工智能的可解释性原则得以延续，但它们已从解释单个决策扩展到解释整个调查链。

图4：代理 workflow 审计追踪（白盒可解释性）

一个完成的调查视图，显示 workflow 路径、每步状态、参考的数据来源、应用的决策标准/风险因素、置信度指示、引用/思维链，以及人类+AI联合的审计追踪；包含一个用于单步的带结构化验证叙述的悬停/详情面板。

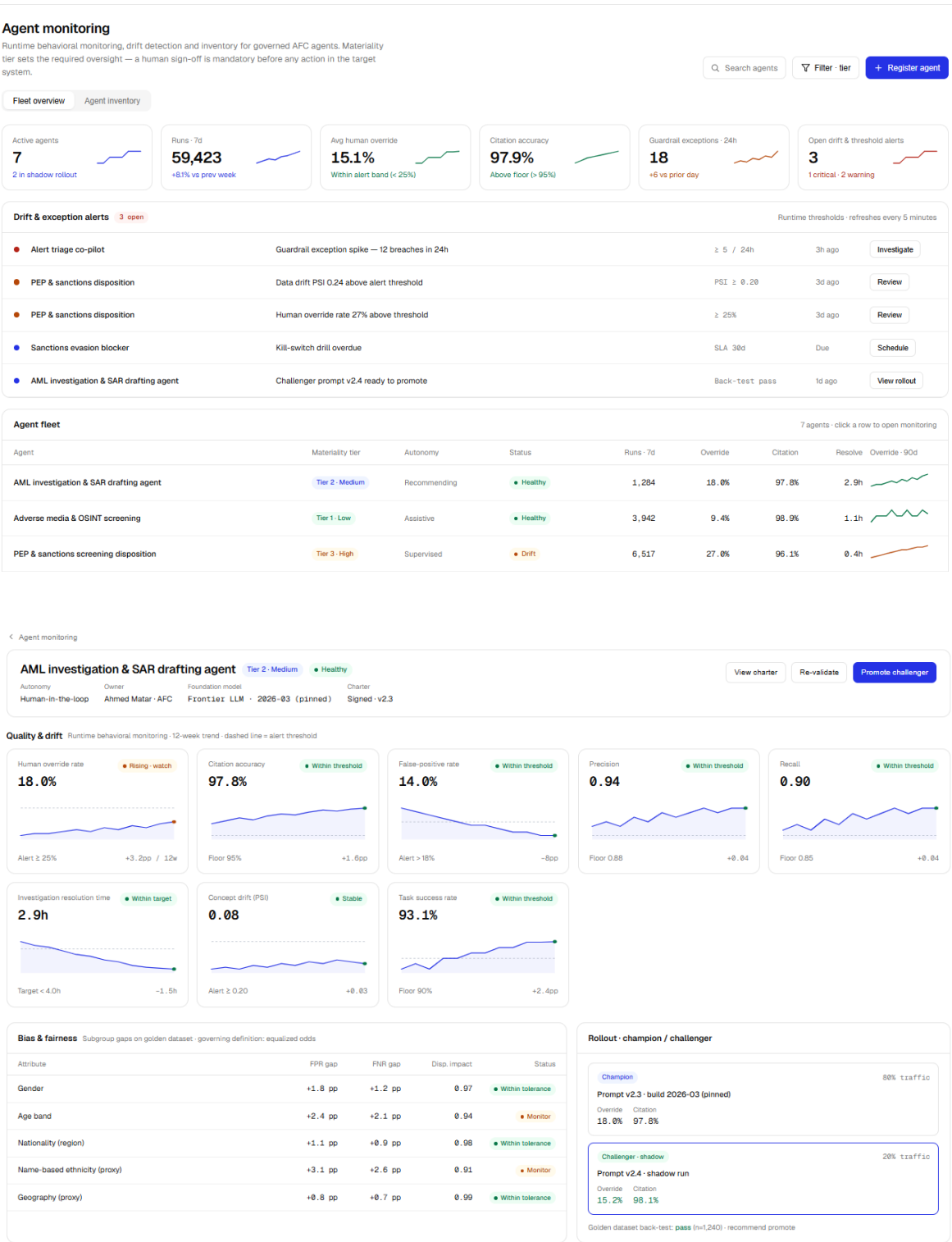


Source: Hawk.

对于自主型AFC系统，其验证不仅限于部署前测试。机构需要证据，证明在整个智能体生命周期中，决策、工具使用、数据来源和人为干预均可被追踪、审查和质疑。

图5：监控与漂移看板

一个监控面板概念，展示指标集（6. 6：精确率/召回率、FPR、告警至SAR比率、覆盖率、引用准确率、数据/概念漂移、解决时间）及其阈值和告警状态。



Agent monitoring

Runtime behavioral monitoring, drift detection and inventory for governed AFC agents. Materiality tier sets the required oversight — a human sign-off is mandatory before any action in the target system.

Q Search agents

▼ Filter: tier

+ Register agent

Fleet overview Agent inventory

Agent & workflow inventory									
Components, versions, permissions & change history - configs and prompts are versioned artifacts									
Agent	Tier	Autonomy	Foundation model	Tools & scope		Data	Prompt	Owner	Last change
AML investigation & SAR drafting agent	Tier 2 - Medium	Recommending	Frontier LLM - 2026-03	5 read	1 write	7	v2.3	Ahmed Matar - AFC	Jun 28
Change history									
Components & versions									
Tool permissions - least privilege									
Foundation model	Frontier LLM - 2026-03 (pinned)			case.read	kyc.read	txn.read	sar.draft.write	Jun 28	Challenger prompt v2.4 entered shadow rollout
System prompt	v2.3 - versioned			View monitoring		Open charter		Jun 28	Prompt v2.3 change reviewed
Retrieval / RAG index	kb-am1 - 2026-06							Jun 10	Retrieval index refreshed
Orchestration	Workflow - 6 tool nodes							May 22	Model build 2026-03 pinned
Adverse media & OSINT screening	Tier 1 - Low	Assistive	Frontier LLM - 2026-02	4 read	no write	4	v1.7	L. Bianchi - AFC	Jun 12
PEP & sanctions screening disposition	Tier 3 - High	Supervised	Frontier LLM - 2026-01	6 read	2 write	9	v3.1	M. Okafor - MRM	May 20
Sanctions evasion blocker	Tier 4 - Critical	Autonomous	Frontier LLM - 2025-12	3 read	3 write	5	v4.0	S. Nakamura - Tech	Jun 05
Alert triage co-pilot	Tier 2 - Medium	Recommending	Frontier LLM - 2026-03	4 read	1 write	6	v2.0	B. Perez - AFC	Jun 24
KYC refresh assistant	Tier 1 - Low	Assistive	Frontier LLM - 2026-02	3 read	1 write	3	v1.2	G. Pessina - Ops	Jul 01
Typology analysis agent	Tier 2 - Medium	Recommending	Frontier LLM - 2026-03	4 read	no write	5	v1.5	L. Bianchi - AFC	Jun 19

Source: Hawk.

持续的监控应将模型、数据、运营和业务风险信号与明确的阈值和升级措施联系起来。这使得验证从一次性批准转变为在代理运行和演进过程中的持续保证。

7. 治理、控制及权限

现有的监管指南始终强调人工智能系统需要清晰的治理架构、明确的问责机制、独立的质疑环节、资产清单以及文档记录。以OCC框架为例，这些治理原则通过类比仍适用于代理式AFC系统，但已超越底层模型，扩展至更广泛的代理式工作流程。政策与治理框架覆盖整个工作流程；角色、职责与问责机制超越底层模型，涵盖更广泛的代理式系统，并且独立的质疑环节适用于代理式工作流程，而不仅限于嵌入式模型。

角色、职责和人机协同决策权限必须明确：谁有权授权哪些代理行为，以及在何种重要性级别下授权。对于调查反洗钱（AML）用例，应确保合格人员批准目标系统中任何具有后果的行动。其他允许有限自主行为的AFC用例应被视为关键级系统，并需接受最严格的授权、监控、隔离和干预控制。

自主系统同样引发了身份和权限的问题，而经典模型则从未涉及这些问题。一个自主体应始终持有其自身的非人类身份。当它代表某人行动时，应使用委托的、代表他人行使的权限（授权而非伪装）；当它处于会话之外运行时，应使用其自身的、有期限的、范围受限的凭证（客户端凭证/工作负载身份）。在所有情况下，其可触及的范围都受限自主体的章程，因此权限和预期用途保持一致。

现有的模型库存实践可以自然地扩展到代理/工作流库存，该库存捕获每个代理的组件、版本、权限和变更历史，并将配置和提示视为可版本控制的、有文档记录的工作件，而非非正式设置。文档记录和审计追踪将保持可供审计的状态，以支持独立挑战、内部治理和监管审查。

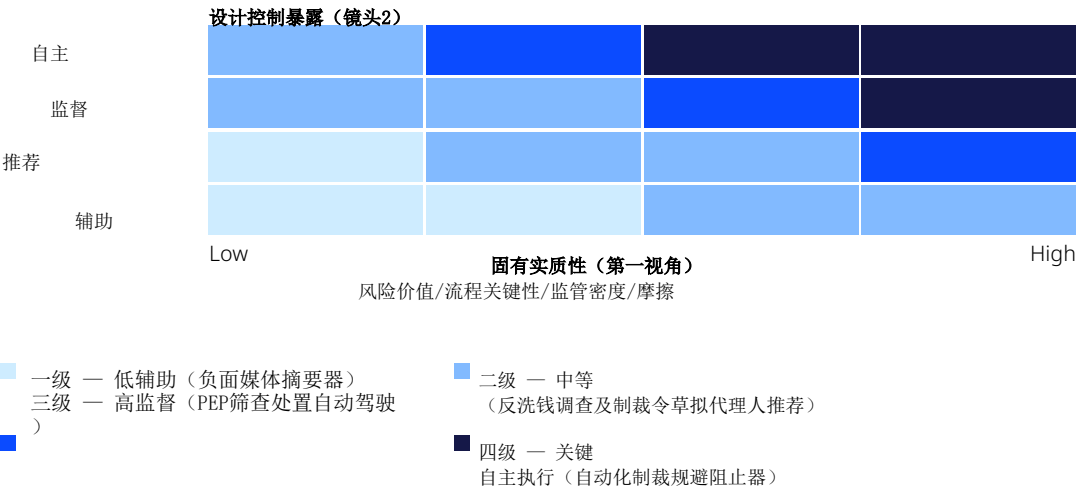
治理也必须通过企业代理保证层进行扩展，该层位于任何个人AFC用例之上。企业人工智能或技术应提供通用注册、评估、追溯存储、监控和发布控制，而AFC拥有代理宪章、域策略、测试、指标、阈值和人类决策权。上述控制对少数代理是可行的，但机构很快将运行数百个代理，可能无法从头开始验证每个代理或全面审查其活动。这不会改变上述特定层级的决策权；它要求周边的保证流程进行扩展。当许多代理共享共同能力时，该能力只需验证一次，并重用证据，而新增的审查则专注于增量风险，同时基于信号的监控会暴露偏差，而不是将注意力均匀分散到每个代理。

最后，治理负责在前一章中引入的跨职能控制：公平性结果及其监控、稳健性/数据中毒测试的日程安排和所有权，以及事件机制——检测、遏制、回滚和披露——并明确界定跨AFC、MRM、技术、法律、审计和供应商利益相关者的升级路径。

表4：按重要性层级划分的决策权梯级

物质性 tier	代理 自主权	所需人力 批准	独立挑战 以及监督
Low	辅助—草稿和 总结；人类 作者的决定	人类决定 一切	标准问答采样
中等	推荐 — 提出 一种有道理的性情	人工审核和 批准每个输出	定期审查；双人复核 样本
High	受控行动——作用于 日常案件，人类 在循环中	人类批准 例外；能够 干预或覆盖	实时监控；全面审计 小径；辅以定期的 独立验证和 定向审查
关键	章程内的自主权 —行为升级 仅例外	预先授权于 界限；强制性的 异常升级	持续保证， 独立挑战， 击杀 切换

图6：治理运营模式与决策权阶梯



欧文咨询和霍肯分析。

8. 供应商和第三方代理解决方案：无需转移责任的责任保障

各机构在构建、采购或整合代理型AFC系统组件方面将有所不同。内部开发可能提供更大的控制力、定制化能力，并能更紧密地与机构特定的数据、工作流程和治理要求保持一致，而第三方解决方案则可能提供更广泛的类型、数据环境、部署模式、代币成本优化和监管预期方面积累的经验。外部供应商也可能提供特定领域的 workflows、预构建的集成、专业知识和经过验证的控制措施，从而可以加速实施和保障。

然而，第三方采购并不能转移治理责任。虽然一个有能力的供应商可以通过提供成熟的测试工具、标准化的证据和可重用的控制组件来减轻机构的保证负担，但内部开发可能提供更直接的系统行为、配置和证据的访问途径。在任一模式下，验证、持续监控、结果分析以及干预的能力仍然是机构的责任。⁵配置好的代理必须根据机构自身的政策、数据、权限、流程和风险偏好进行评估。供应商通过提供机构进行高效评估所需的配置透明度、测试工具和标准化证据来支持这一点。

承担义务的主体必须能够验证配置的代理，在生产环境中监控它，评估供应商和模型变更，调查故障，重新验证材料更新，并应对独立或监督性的挑战。这些义务的适用性与系统是自行构建还是购买无关。采购方式决定了该机构履行这些义务的能力如何。当供应商提供提示、组件版本、工具路径行为、运行时跟踪、故障记录和变更历史——并附带与之协作的工具——这可以加速机构的保证活动，并支持更一致的证据。

第5号运营手册2026-13a，第七节（供应商及其他第三方产品）：即使组件是专有的，供应商模式风险管理原则仍然适用。

技术可以外部采购；保证结果仍是机构的责任。供应商可以提供企业代理保证层的大量组件——越来越像是一种产品化能力而非定制化让步——但机构必须保留对管理已部署系统所需的证据和干预权的直接或合同强制执行访问权限。技术可以外部采购，而保证结果仍是机构的责任。

因此，确保访问权限应被视为既是采购标准，也是部署门槛。在批准第三方代理之前，机构应确定其能否配置代理以符合自身政策；在机构特定的代表性、边缘性和对抗性案例上对其进行测试；重建并导出其执行轨迹；识别当前生效的模型、工具、提示和配置；接收重大变更的通知；进行独立挑战；使用自身阈值监控结果；并在必要时暂停、限制或回滚代理。如果提供方展示了并合同上支持这些能力，评估可以侧重于确认并记录其针对特定部署的充分性；否则，可能需要额外的权利或补偿性控制。

这些要求是结果导向的。根据重要性，可以通过架构文档、版本清单、受控测试、可追溯导出、独立保证报告、合同审计权以及联合监控来提供充分保证。

表5：第三方代理系统的最低保障访问权限

保障能力 最低要求	
客户可配置性	机构可以定义或批准章程、政策、工具权限、数据访问。 自主程度、升级逻辑和人工审批点
Institution-specific 可检验性	一个沙盒、测试租户或等效机制支持黄金数据集、回归测试。 边缘情况，以及使用代表性机构场景进行对抗性测试
运行时可观测性	运行级别证据涵盖 workflow 步骤、模型和工具交互、源数据血缘关系 行使的权限、错误、人工干预以及生效的版本
证据便携性	痕迹、检测结果、监控数据和相关记录可以被导出到 该机构的自身证据、风险或档案保存环境
改变管理	该机构收到关于实质性模型、提示、编排、工具或 控制变更，并且可以在部署前或部署后立即进行回归测试
独立挑战	该机构及其独立的控制功能可以测试结果、审查相关 控制证据，获取访问失败信息，并质疑供应商的结论
干预并退出	该机构可以暂停服务、撤销代理权限、降低自主性、回滚 调整背景材料，保留历史证据，并有序撤离
数据和安全控件	租户隔离、数据驻留、子处理器透明度、保留控制以及 使用客户数据进行基础模型训练的禁令已有记载。 并且可执行

要求应与材料性相匹配。机构与供应商应在初期就商定拟议层级所需的证据和干预权，并确认平台能提供这些内容。若某项能力尚不存在，可行的路径是制定联合路线图：最初在较低自主权层级部署，在平台周围添加独立控制，或缩小范围直至该能力可用。如果这些措施未能提供与拟议层级相称的保证，机构就不应在该层级部署。

通用保证标准或平台级认证最终可通过证实组件清单、追溯模式、评估方法、变更通知、安全控制和审计员访问的基本标准来减少重复评估。它们不会取代针对特定机构的配置代理的验证。

第三方采购可以加速部署，但这并不转移责任。机构应保留管理代理人所需的相关证据、访问权限、干预权利和独立保证，以确保根据其重要性对其进行管理。

9. 示例：反洗钱调查代理

为使框架具体化，可考虑一个AML调查代理，该代理负责对一级警报进行研究和草拟。它不监控实时交易流；一旦该机构的主要检测系统发出警报，该代理就会在机构配置的工作流程中对该特定警报进行深入调查。

附件7：受监管的AML调查工作流程的示例实施

使用合成数据进行鹰式示例。顶部：针对人类（HITL）的警报摘要、评估和行动建议。中部：遵循FI标准操作程序（SOP）的代理工作流程路径审计追踪。底部：类型评估和潜在风险评估。

 **Investigation Summary** 95%

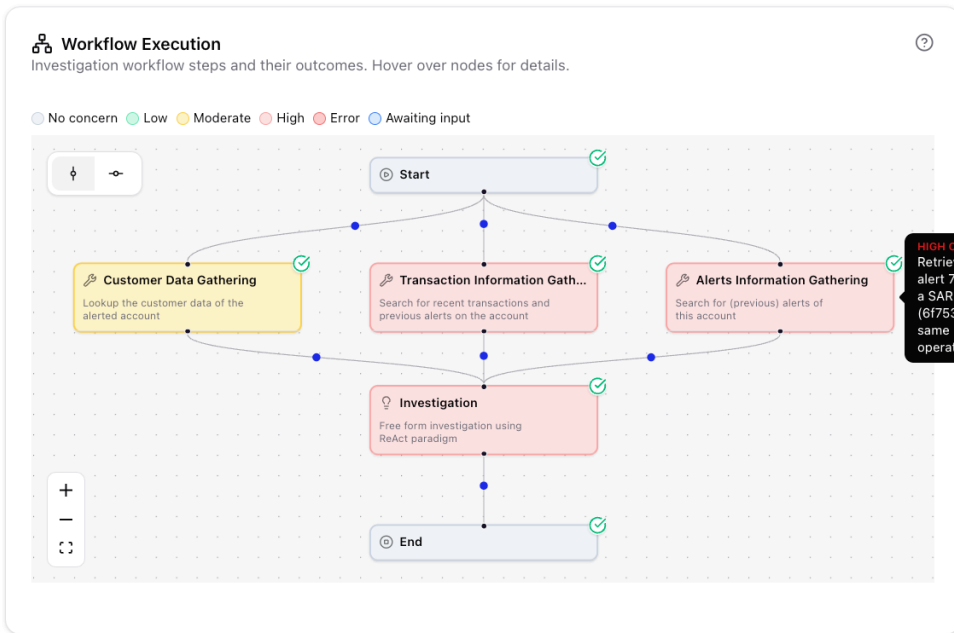
AI-Generated Analysis and Recommendation

 **Escalation Recommended**
This alert requires escalation due to identified risk indicators. Please follow organizational protocols for handling high-risk alerts.

Overview
Auto Refactory Co. received **€18,000 across 6 overnight transactions** from its own majority shareholder Bernhard Heils, who used **multiple accounts and name variants** — a pattern consistent with **structuring (smurfing)** and **multiple identity / account obfuscation**.

Outcome
Escalation is warranted: a **SAR was previously filed** confirming prior investigator agreement, and a **classic structuring pattern** combined with a **self-dealing counterparty** leaves no credible benign explanation. Next steps should include **obtaining a source of funds explanation** from Bernhard Heils, **identifying all five source accounts** used in the transactions, and **reviewing the prior SAR filing and linking findings to the open related alert**.

受监管的代理机构可在保持人类问责制的同时加速反洗钱调查。其章程、风险等级、权限边界、验证证据和升级路径必须确定其可执行的操作，以及人类批准仍然必需的环节。



Detected Typologies

Known patterns identified during the investigation

Structuring (Smurfing)	95%	▼
Self-Dealing / Insider Layering	82%	▼
Unusual Transaction Timing / Operational Anomaly	78%	▼
Multiple Identity / Account Obfuscation	80%	▼
Cross-Border Opacity / Jurisdiction Mismatch	55%	▼
SAR Evasion / Repeat Suspicious Activity	72%	▼

Q

Key Findings

6 Risk

2 Mitigating

Evidence and insights surfaced by the investigation

€18,000 structured across 6 overnight transactions

Risk 98%

Counterparty is majority shareholder using multiple accounts

Risk 97%

- All 6 transactions originate from Bernhard Heils (60% owner of Auto Refactory Co.)
- Three name variants used: Bernhard Heils / Bern Heils / B. Heils
- Five distinct source account numbers used across the cluster
- Self-dealing pattern: shareholder sending funds to own company via fragmented transfers

Related Typologies (4)

Structuring (Smurfing)

Self-Dealing / Insider Layering

Multiple Identity / Account Obfuscation

Cross-Border Opacity / Jurisdiction Mismatch

Sources (38)

Case 7fc05b8f-2712-4366-8539-4612d3f25f09

Case 6f753f24-e3a6-426f-80be-69fb121f735a

Case 3219aa70-0876-4c48-8295-d50cc554e9b8

Case 5003ab96-16bd-4ad7-bbb3-562b0e3687ce

Case 24466c86-e81e-4095-8b3e-20a1baf56759

Case a9e9375d-e77d-42b3-9d26-5ad47031cfcf

Case 225f48f1-9cf8-49e5-a4a0-8bef587a443c

Case 9511100c-76c5-4bb7-8f75-d7e67daa4ee2

Case 1906a229-7607-4ba5-ad15-5dab343fac20

Case a881413e-923f-4106-ba44-24540d2fa78d

Source: Hawk.

授权与重要性。 代理人的授权仅限于调查和草拟：整合内部和外部数据、总结案例背景、识别相关类型、建议后续步骤、并准备SAR叙述草稿——始终保留审计追踪，且绝不冻结账户、终止客户关系或向金融情报单位报告。在第四章的重要性矩阵中，此项属于中高重要性，因为其输出结果将用于监管决策，但它未达到最高级别，正是因为其无法采取行动。这一分类决定了控制集的设置。在中高重要性级别下，它会调用决策权等级第七章的建议层级——要求对每项处置进行人工强制审批、对样本进行独立挑战，并对推理链进行完整运行时监控和记录——而不是仅保留给被授权采取行动的代理人使用的实时监督、仅限异常的升级和强制停止功能。一旦机构允许代理在目标系统中采取任何行动，所需的治理层级将提升至最高级别，并引入最全面的控制集。

验证、检查点、监控和证据。 在部署前，代理程序会在典型案例和对抗性案例上进行端到端测试；任何处置决定前都必须进行人工介入检查点；运行时监控会追踪第6章设定的指标；并且每个发现都由可解释性要素支撑——路径、来源、标准、置信度和引用。这是一个具体的工作流程：首先触发结构化警报，代理程序并行收集KYC信息和交易历史，构建时间线，筛选负面媒体，识别候选类型，并生成包含建议处置方案和初步叙述的结构化摘要。分析师随后对输出结果进行质询，接受或修正，并做出最终决定。

具体而言，供应商可以如此支持在第8章建立的保障能力：

保障能力	最低期望	供应商支持示例
客户可配置性	机构可以制定或批准章程。策略、工具权限、数据访问、自主制定策略和标准操作程序，并将其整合为能动型工作流程级别、升级逻辑、以及人工审批点，并独立配置每个节点——工具，	工作流管理器：该机构将其数据来源，自主性，升级逻辑以及人类审批点。工作流是按领域分类（反洗钱、欺诈、筛查、）SAR叙述）并与独立的提示和案例-动作语义。类型学管理层允许该机构进行策展、版本控制。并为其自身类型分类以依附于个体工作流步骤
Institution-specific 可检验性	沙盒、测试租户或等效机制 支持 golden-dataset、回归、边缘案例 并且使用有代表性的对抗性测试 制度场景	机构专用沙盒租户 专项测试，并与历史数据回溯 该机构自身的黄金数据集——正在运行 机构自行服务或联合服务 供应商
运行时可观察性	运行级别证据涵盖工作流步骤、模型，每次调查均按运行记录。 以及工具交互、来源追溯、权限 工作流运行视图 — 执行的工作流步骤 已执行、错误、人工干预以及所调用的工具和数据源、模型输出 生效版本	类型匹配，以及分析师干预 在流程版本生效的情况下。代理式 绩效衡量增加了定量的 决策质量报告，基准测试 代理人的决策与分析师的结果相悖， 文档政策
证据可移植性	痕迹、检测结果、监控数据以及相关的运行记录、决策依据和案例审计 记录可导出到机构的自有轨迹中，按租户保留，并可访问。 证据、风险或记录保存环境制度以供其出口自己的证据	记录保存环境
变革管理	该机构收到适当的通知 材料模型、提示、编排、工具，或 控制更改并可以执行回归 部署前或部署后立即进行测试	材料平台的变更已传达 通过发布说明，该机构可以在它的沙盒中对其代理进行回归测试 在领养之前。工作流程和类型 版本已置顶：一个更新版本 以通知形式出现，并并排显示 仅在明确制度中采用差异。 批准——从不默默进行。
独立挑战	该机构及其独立控制 功能可以测试结果，审阅相关 控制证据，获取访问失败信息 并质疑供应商的结论	沙盒测试代表性变更 回溯
干预与退出	该机构可以暂停服务，撤销 代理权限，降低自主性，回滚 实质性变更，保留历史证据 并执行有序退出	完全自助控制：该机构可以 激活、暂停或停用代理，修改 或撤销工作流步骤和工具权限 减少自主权，禁用连接器 来源，并更改运行计划——而没有 供应商参与。历史运行证据 当代理被暂停时，会保留。 工作流已停用。
数据和安全控制	租户隔离，数据驻留，子处理器 严格租户隔离，并有文档记录的租户 透明度、保留控制及禁止架构；数据驻留、分包商 使用客户数据来训练基础模型 模型已文档化且可执行	并且留存期限已记录在案。 合同约定。客户数据并非 用于训练或改进基础模型。

10. 从框架到制度实践

机构不太可能一步到位达到目标状态。一个务实的实施路径始于建立可见性、所有权和边界明确的权限；然后标准化可重用的控制措施和证据；最终将保证和执行嵌入到机构的技术平台中。

第一阶段：建立可见性、所有权和边界

- 库存代理活动：识别已在使用或处于试点阶段的AFC代理和类似代理的工作流程，指派负责的负责人，并使用第四章框架对每个进行分类。
- 定义允许的操作边界：为每个代理建立一份章程，涵盖其目标、范围、授权权限、禁止行为、数据与工具访问权限，以及所需的人为决策和升级节点。
- 明确治理主页：更新模型和非模型治理边界，以便在AFC、MRM或AI风险、技术、网络、数据、隐私、法律、审计和第三方风险方面，使能动式工作流具有明确的生命周期、审批路径和所有权模型。

第二阶段：标准化可重用控件和证据

- 开发可复用的代理原型和控制模式：为常见的重复使用场景定义通用设计，并辅以相称的审批要求、人工监督模型、授权模式、评估标准及证据预期。
- 建立通用的验证和证据标准：要求端到端测试、证据溯源、执行追踪、变更记录、监控阈值和再验证触发器，并在适当情况下重用适用于通用能力的基线保证证据，同时每个配置的代理仍需接受端到端、机构特定的验证。
- 制定采购要求：要求第三方解决方案支持机构特定测试、追溯与证据导出、配置透明、物料变更通知、独立挑战、干预权以及有序退出。

第三阶段：将保障嵌入平台

- 实施企业代理保障层：将通用注册、身份识别、策略执行、测试、发布控制、追踪、监控、暂停和证据保留等功能应用于机构的AI工厂、代理平台和第三方解决方案。
- 迈向持续保证：尽可能自动化控制检查和发布关卡，监控运行时行为和结果，并将异常连接到事件管理、独立挑战和定期治理审查。

这种排序不应被理解为严格线性。机构可以并行发展不同的能力，但进程很重要：可见性和权威提供了控制基础；标准化使治理可扩展；平台层面的执行使其可持续。

11. 结论

金融机构无需等待专门的代理式人工智能监管，即可在金融科技领域部署代理式系统。现有的监管指南和行业框架已提供可类推适用的有用原则，尽管它们并未为代理式人工智能建立一套完整的治理标准。挑战并非要取代这些原则，而是要将它们从治理单个模型扩展到治理更广泛的代理式系统——包括其编排、工具、数据访问、授权委托、人工监督和审计追踪。无论是内部构建还是向第三方采购，每个实质性代理都应连接到企业代理保障层，以便机构能够对其进行测试、观察、质疑、约束和停止。

这一更广泛的视角的一个重要启示是，设计选择可以在不影响用例固有重要性的前提下，实质性影响残余风险和部署条件。虽然用例的固有重要性无法改变，但可以通过围绕自主性、工具权限、工作流约束、护栏和人工监督等方面的工程选择来有意塑造代理系统的残余风险。因此，治理不仅是一门合规学科，也是一门架构学科。

最终，治理问题已从“每个模型组件是否适用？”扩展到“AI支持的调查行为是否具有边界、基于证据、可审计、可质疑、可监控、可解释，并与机构的AFC风险画像保持一致？”能够用证据回答第二个问题的机构，将更有信心地采用自主AFC。

附录A——主要参考文献

- 美国货币监理署公告2026-13及跨机构《模型风险管理监督指南》（美国货币监理署2026-13a），美国货币监理署/美联储/联邦存款保险公司，2026年4月17日。
- 沃尔夫斯贝格集团，《在金融犯罪合规中使用人工智能和机器学习的原则》，2022年12月。
- 金融行动特别工作组，《前瞻扫描：人工智能与深度伪造》，2025年12月22日。
- 美国国会，《反洗钱法2020》，公共法第116-283第F部分，2021年1月1日。

免责声明

奥利弗·怀特曼 (Oliver Wyman) 对于本报告或任何基于本报告所载结果、建议或意见所采取的行动或做出的决定，不对任何第三方承担任何责任。

本报告不构成法律建议，法律建议只能由律师提供，您应当寻求律师的建议。此处所表达的观点仅适用于本报告所述目的，并自本报告日期起有效。本报告全部或部分内容所依据的由他人提供的信息，据信是可靠的，但未经核实。对此类信息的准确性不作任何保证。公开信息、行业和统计数据来源于 Oliver Wyman 认为可靠的来源；然而，Oliver Wyman 对此类信息的准确性和完整性不作任何陈述，且已在不作进一步核实的情况下接受了此类信息。对于市场状况或法律法规的变化不承担责任，亦不承担修订本报告以反映自本报告日期起发生的变化、事件或状况的义务。

威灵顿咨询公司（Oliver Wyman）， Marsh（纽约证券交易所代码：MRSH）旗下的企业，是一家以深刻行业洞察、大胆创新及协作方式见长、能够化繁为简、助力组织应对其最具定义性的转型时刻的管理咨询公司。Marsh是全球在风险、再保险与资本、人力资源与投资以及管理咨询领域的领导者，为130个国家的客户提供建议。公司年营收达270亿美元，拥有超过9.5万名同事，致力于通过独特的视角帮助客户建立信心，从而蓬勃发展。

更多信息，请访问 oliverwyman.com，或在领英（LinkedIn）和推特（X）上关注我们。 —

美洲
+1 212 541 8100

欧洲
+44 20 7333 8333

亚太地区
+65 6510 9700

印度、中东和非洲
+971 (0) 4 425 7000

作者

斯特凡诺·博埃齐奥
伙伴，奥利弗·怀曼

大卫·蔡
伙伴，奥利弗·怀曼

沃尔夫冈·伯纳
联合创始人兼首席产品官
鹰眼人工智能

费利克斯·贝克汉博士
首席人工智能官，鹰智科技

罗伯特·施穆克博士
产品副总裁——反洗钱，鹰眼人工智能

版权所有。未经 Oliver Wyman 书面许可，本报告不得全部或部分复制或转载。
在此方面，奥利弗·怀曼对第三方行为概不负责。

本报告中的信息与观点由 Oliver Wyman 整理。本报告不构成投资建议，亦不应被视为投资建议或替代专业会计师、税务、法律或财务顾问的咨询。Oliver Wyman 已尽一切努力使用可靠、最新且全面的信息与分析，但所有信息均未经保证，无论明示或暗示。Oliver Wyman 不承担更新本报告中信息或结论的责任。对于因依据本报告或本报告中引用的任何报告或信息来源所采取或未采取的任何行动而导致的任何损失，或因任何后果性、特殊或类似损害（即使已被告知此类损害的可能性），Oliver Wyman 不承担责任。本报告不构成买卖证券的要约或招揽买卖证券。未经 Oliver Wyman 书面同意，本报告不得出售。